Database-audit Devision aanmeldplatform

Nov 11, 2026 · @Rodney Rossewij

De database is klein, schoon en functioneel goed afgeschermd, maar structureel te breed: één tabel Aanmeldingen draagt 101 velden waarvan 10 JSON-velden, personen worden op minstens 15 plekken met losse naam- of e-mailtekst aangeduid, en geheimen staan onversleuteld opgeslagen. Er is nog niets aangepast; dit rapport vraagt om toestemming per fase.

Afbakening en werkwijze

Onderzocht is één applicatie: het Devision-aanmeldplatform in Zite-workspace 4e08667dafae8387. Twee apps delen één database: het partnerportaal “Aanmelding 3B” (extern, 52 endpoints, toegang via persoonlijke sleutel) en “Aanmeldingen beheer” (intern, 156 endpoints, Zite-login met rollen). Het beursformulier in de andere workspace valt erbuiten.

Technologie. Zite-database op PostgreSQL, benaderd via de Zite-SDK (`findAll` / `findOne` / `create` / `update` / `delete` , filters, `fields` , `sort`) en alleen-lezen SQL. Geen DDL, geen transacties, geen triggers of views onder eigen beheer. Koppelvelden zijn door Zite beheerde relaties, in SQL zichtbaar als JSON-lijsten met id’s.

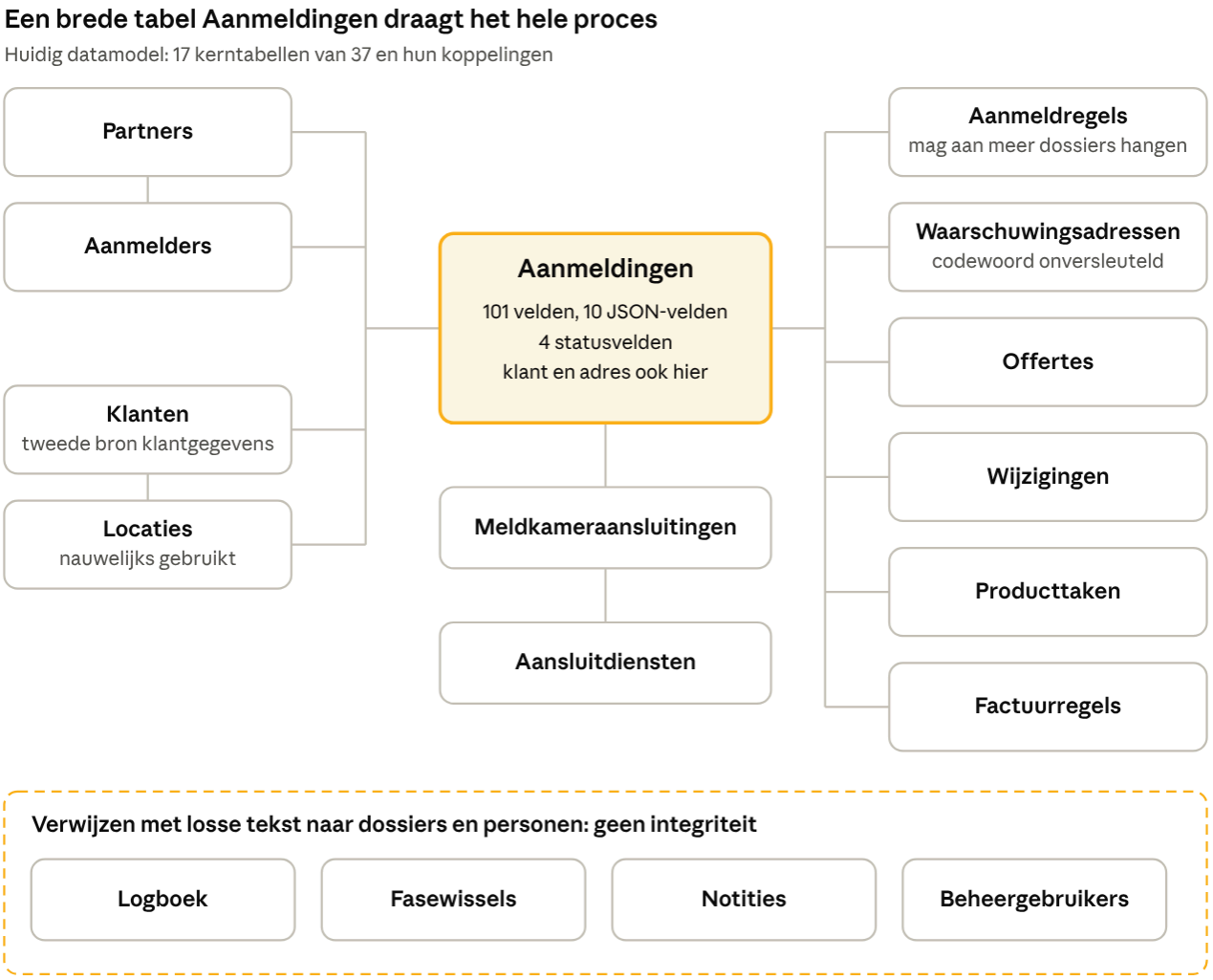
Hoe gemeten. Schema uit `zite.schema.json` (37 tabellen, alle velden en typen); een lezend controlescript over alle records (koppelingen, uniciteit, geheimen, levenscyclus, geldigheid van JSON); codeanalyse van alle 208 endpoints (toegangscontrole, tabelgebruik, query’s); tijdmetingen van de drukste endpoints. Er is niets gewijzigd of verwijderd.

Niet beoordeeld, omdat Zite het niet ontsluit:

- indexen, constraints en execution plans: de Postgres-catalogus (`pg_indexes` , `information_schema`) is geblokkeerd;
- back-ups, herstelmogelijkheden en point-in-time recovery: beheerd door Zite, niet zichtbaar;
- gedrag bij 10x of 100x data: niet getest met echte belasting, alleen afgeleid uit hoe de code laadt.

Kanttekening bij de data. Het is een testomgeving met 6 dossiers, 6 partners en 229 logregels. Een schone meting zegt hier weinig over de structuur; de structurele bevindingen wegen daarom zwaarder dan de tellingen.

Huidig datamodel



huidig datamodel · 17 kerntabellen

Alles hangt aan Aanmeldingen; logboek, fasewissels en notities verwijzen met tekst-id's, en naar Beheergebruikers verwijzen andere tabellen alleen met naam of e-mail.

Database inventory

Alle 37 tabellen hebben een door Zite beheerde primaire sleutel `id` (uuid) en een weergaveveld; indexen en constraints zijn niet uit te lezen. "Gebruik" = aantal endpoints in portaal (P) en beheer (B) dat de tabel leest of schrijft, plus gedeelde servermodules (S).

Tabel	Doel	Records	Velden	Koppelt naar	Gebruik P / B / S	Bevinding
Aanmeldingen	Het dossier: aanvraag tot aansluiting, klant, object, fasen, controles	6	101	partners (2x), aanmelders (2x), klanten, locaties, ketens + 12 teruglinks	23 / 44 / 26	God-tabel: 10 JSON-tekstvelden, klant- en adresgegevens dubbel met Klanten en Locaties, 4 statusvelden

Tabel	Doel	Records	Velden	Koppelt naar	Gebruik P / B / S	Bevinding
Aanmeldregels	Verkochte diensten per aanvraag	40	9	aanmeldingen, diensten (beide “meerdere”)	2 / 2 / 6	Koppeling staat meerdere dossiers toe waar er één hoort
Waarschuwingsadressen	Contactpersonen met codewoord	6	14	aanmeldingen (“meerdere”)	5 / 11 / 5	3 codewoorden onversleuteld; zelfde cardinaliteitsfout
Meldkameraansluitingen	Operationele aansluiting bij de meldkamer	6	31	aanmeldingen, klanten, locaties, partners	4 / 19 / 8	Checklist en configuratie als JSON
Aansluitdiensten	Actieve diensten per aansluiting	15	16	meldkameraansluitingen, diensten, aanmeldingen	2 / 8 / 7	Dossier dubbel opgeslagen (ook via de aansluiting)
Factuurregels	Te factureren regels	3	27	aanmeldingen, diensten	1 / 12 / 3	3 regels zonder frequentie, btw-code en grootboek
Factuurruns	Facturatierondes met snapshot	0	15	—	1 / 4 / 0	Regels als JSON-snapshot (bewust)
Offertes	Offerteversies, klantakkoord	9	19	aanmeldingen	5 / 1 / 4	Akkoordsleutel en tekencode als platte tekst
Herinneringen	Geplande offerteherinneringen	15	11	offertes, aanmeldingen	1 / 3 / 2	In orde
Wijzigingen	Wijzigingen en opzeggingen van partners	1	26	partners, aanmeldingen	7 / 18 / 11	Vervolg en voorstel als JSON
Producttaken	Taken per team, notitie- en behoudtaken	0	13	aanmeldingen, productacties	0 / 11 / 4	Eigenaar als e-mailtekst
Onboarding	Welkomstgesprek na activering	2	17	aanmeldingen, meldkameraansluitingen	0 / 14 / 6	Antwoorden en historie als JSON
Commerciele Kansen	Kansen uit onboarding en opzeggingen	0	11	aanmeldingen, onboarding, aanmelders, partners	1 / 5 / 4	In orde
Partners	Installatiebedrijven, huisstijl, onboarding	6	33	opvolgbedrijven + 11 teruglinks	7 / 39 / 26	Toegangscode platte tekst; 4 JSON-velden (instellingen, onboarding, pakketten, meldingsprofiel)
Aanmelders	Medewerkers van partners (sales, monteur)	8	18	partners, vestigingen + 4 teruglinks	11 / 12 / 14	Toegangscode platte tekst; teruglink “aanmeldingen1” onduidelijk benoemd
Vestigingen	Vestigingen van partners	2	7	partners	1 / 3 / 2	In orde
Klanten	Eindklanten	6	13	partners, ketens	1 / 2 / 4	Tweede bron naast de klantvelden in Aanmeldingen
Locaties	Objectadressen	6	10	klanten, partners	0 / 0 / 1	Tweede bron naast het objectadres in Aanmeldingen; nauwelijks gebruikt
Ketens	Winkelketens met raamafspraak	0	19	—	0 / 3 / 3	In orde
Diensten	Productcatalogus	105	29	partners, productacties, zichzelf	2 / 19 / 9	In orde
Partnertarieven	Prijs per partner en dienst	334	16	partners, diensten	2 / 17 / 8	Grootste tabel; groeit met indexaties
Indexaties	Prijsindexaties	0	11	—	0 / 3 / 1	Oude prijzen als JSON (terugdraaien)
Opvolgbedrijven	Alarmopvolgers	13	7	partners	0 / 6 / 2	In orde
Productacties	Wat bij een product hoort	4	15	diensten	0 / 1 / 1	In orde

Tabel	Doel	Records	Velden	Koppelt naar	Gebruik P / B / S	Bevinding
Beheergebruikers	Devision-medewerkers en rollen	3	12	—	0 / 13 / 4	Naar hen wordt overal met losse e-mailtekst verwezen, niet met een koppeling
Beheersessies	Tijdelijke meekijk- en namens-links	10	7	aanmeldingen, aanmelders	0 / 4 / 1	10 verlopen tokens nooit opgeruimd
Concepten	Tussentijds opgeslagen aanvragen	1	8	— (partnerId als tekst)	3 / 0 / 1	Partner niet gekoppeld
Logboek	Audittrail, verzendlog, automatiseringen	229	6	— (recordId als tekst)	6 / 17 / 14	Drie functies in één tabel; 14 regels wijzen naar verdwenen records; geen oud/nieuw-waarden
Fasewissels	Fasehistorie per dossier	38	5	— (dossierId als tekst)	0 / 1 / 2	Nieuw; goede smalle eventtabel
Notities	Interne notities	0	7	— (recordId als tekst)	0 / 2 / 1	Polymorf zonder koppeling (bewust)
Dossierbezoeken	Wie heeft een dossier open	0	5	—	0 / 1 / 0	Ruimt zichzelf op
Instellingen	Configuratie als sleutel/waarde	6	4	—	0 / 19 / 12	JSON zonder schema in de database
Documenten	Documentbibliotheek	3	18	—	1 / 3 / 1	Partners en downloads als JSON-lijst van id's
Documentpakketten	Pakketten per partner	7	8	—	0 / 4 / 1	Documenten als JSON-lijst van id's
Onboardingtemplates	Sjablonen partner-onboarding	4	8	—	0 / 4 / 0	In orde
Onboardingvragen	Vragen welkomstgesprek	21	16	—	0 / 1 / 1	In orde
Wizardregels	Regels aanvraagwizard	1	9	—	1 / 2 / 0	In orde

Rapport 1 — Database health score

Gemiddeld 61 van 100 over tien beoordeelde onderdelen: de data zelf is schoon, het model eromheen is te breed en leunt op de code voor regels die in de database horen. Criteria: 100 = enterprise-niveau zonder bevindingen; per aantoonbare structurele bevinding gaat er af naar ernst.

Onderdeel	Score	Onderbouwing
Databasearchitectuur	60	Heldere domeintabellen per proces; maar één God-tabel (Aanmeldingen, 101 velden) en een Logboek met drie functies
Datamodel	55	Klant- en adresgegevens op twee plekken; minstens 15 verwijzingen naar personen als losse naam- of e-mailtekst; 3 koppelingen met verkeerde cardinaliteit

Onderdeel	Score	Onderbouwing
Normalisatie	50	1NF geschonden: 29 tekstvelden bevatten gemeten JSON (8 in Aanmeldingen, nog 12 lege velden zijn als JSON bedoeld), waaronder 4 JSON-lijsten van id's; 3NF geschonden door afgeleide kopieën (aanvraag op Aansluitdiensten)
Data-integriteit	65	Koppelvelden door Zite bewaakt en 0 verweesde koppelingen; maar geen UNIQUE- of CHECK-constraints mogelijk, 5 tabellen met tekstverwijzingen zonder integriteit, 14 verwezen logregels
Datakwaliteit	90	Gemeten op alle records: 0 duplicaten, 0 ongeldige fasen, 0 ongeldige JSON in domeinvelden; 3 van 3 factuurregels missen frequentie, btw en grootboek
Query performance	70	Na vandaag: lijsten 0,2–0,5 s, dossier 0,7–1,6 s; nog 35 plekken die hele tabellen laden en in geheugen koppelen
Indexering	Niet beoordeeld	Postgres-catalogus en execution plans zijn in Zite niet toegankelijk; indexen beheert het platform
Security	60	Sterke sleutels (32 tekens, cryptografisch) en scheiding tussen partners in elk endpoint; maar codewoorden, toegangscodes en tokens als platte tekst, geen databasebeveiliging per rij, verlopen tokens blijven staan
Schaalbaarheid	55	Hele tabellen per aanroep en pagina's van 1.000 achter elkaar: lineaire groei van laadtijd; geen paginering in lijsten naar de browser
Onderhoudbaarheid	60	Getypeerde SDK, gedeelde servermodules, vergelijkingstests; maar JSON-schema's alleen in code, veldlijsten handmatig bij te houden, 208 endpoints
AI-readiness	50	Fasewissels en notities zijn bruikbaar; kernkennis zit in ongestructureerde JSON en vrije logtekst

Datakwaliteitsscore (model). Zes dimensies, elk 0–100 als aandeel geslaagde controles, gelijk gewogen. Gemeten: completeness 95 (factuurregels incompleet), consistency 100 (status past bij fase, aansluiting bij fase), accuracy niet meetbaar zonder bron, uniqueness 100 (11 uniciteitscontroles), validity 100 (fasen, JSON), referential integrity 96 (14 van 229 logregels wijzen naar niets). Score over vijf meetbare dimensies: 98.

Rapport 2 — Belangrijkste databaseproblemen

Zeventien aantoonbare problemen; de twee kritieke gaan over geheimen die leesbaar in de database staan. Prioriteit: P0 kritiek, P1 hoog, P2 middel, P3 laag. Complexiteit: S (uren), M (dagen), L (weken).

#	Probleem	Tabel(len)	Oorzaak	Impact	Prio	Oplossing	Complex
1	Codewoorden onversleuteld (3 van 3)	Waarschuwingsadressen	Sleutel `ZITE_CODEWOORD_SLEUTEL` niet ingesteld; code valt terug op platte tekst	Bij een datalek zijn codewoorden direct bruikbaar om een alarm af te melden	P0	Sleutel instellen, bestaande codewoorden eenmalig versleutelen, opslaan zonder sleutel weigeren	S
2	KVK-sleutel nog niet geroteerd	(omgeving)	Eerder gedeeld; rotatie staat open	Misbruik op jullie KVK-account	P0	Sleutel roteren in de Zite-omgeving	S
3	Toegangssleutels en tokens als platte tekst	Aanmelders, Partners, Beheersessies, Offertes, Aanmeldingen	Opzoeken op exacte waarde	Wie de database leest, kan inloggen als elke partnermedewerker of klant	P1	Alleen een SHA-256-hash opslaan en daarop zoeken; links blijven werken	M
4	Verlopen beheersessies blijven staan (10 van 10)	Beheersessies	Geen opruimtaak	Onnodige geldige-ogende tokens; groei	P1	Nachtelijke opruiming in de bestaande bewaartermijntaak	S
5	Koppeling staat “meerdere” toe waar één hoort	Aanmeldregels (2x), Waarschuwingsadressen	Veldinstelling `allowMultiple`	Een regel of contact kan aan twee dossiers hangen; code pakt stil de eerste	P1	Veld op “één” zetten (nu 0 overtredingen)	S
6	Factuurregels incompleet (3 van 3)	Factuurregels	Frequentie, btw-code, grootboek niet ingevuld	Factuurrun en verwachte facturen tonen €0	P1	Gegevens invullen; run weigeren bij ontbrekende velden	S
7	Geen UNIQUE- of CHECK-regels in de database	Aanmeldingen, Aanmelders, Partners, Instellingen	Zite biedt deze constraints niet; bewaking zit verspreid in code	Dubbele referentie-, aansluit- of partnercodes mogelijk bij een fout of race	P2	Centrale controles bij schrijven + dagelijkse integriteitscontrole die meldt	M
8	God-tabel Aanmeldingen (101 velden, 10 JSON)	Aanmeldingen	Elke procesfase voegde velden toe	Elke lijst sleept de hele rij mee; wijzigingen raken alles; schema onleesbaar	P2	Satelliettabellen per fase: Installatie, Controles, Commerciele afspraak	L
9	Klant en adres op twee plekken	Aanmeldingen, Klanten, Locaties	Klantvelden gekopieerd naar het dossier	Correctie op één plek wordt niet overal zichtbaar; Locaties vrijwel ongebruikt	P2	Eén bron (Klanten, Locaties); dossier houdt alleen een momentopname voor facturen	L

#	Probleem	Tabel(len)	Oorzaak	Impact	Prio	Oplossing	Complex
10	Personen als losse tekst (15+ velden)	Aanmeldingen, Producttaken, Beheergebruikers, Notities, Logboek	Naam of e-mail in tekstvelden	E-mailwijziging breekt proceseigenaarschap en taken	P2	Koppeling naar Beheergebruikers voor eigenaar, vervanger, toegewezene	M
11	Logboek doet drie dingen	Logboek	Audit, verzendlog en automatisering in één tabel	Groeit het snelst; geen oud/nieuw-waarden; 14 regels naar verdwenen records	P2	Verzendlog apart; auditregels met entiteit, veld, oud, nieuw, bron	M
12	Hele tabellen laden (35 plekken)	Aanmeldingen, Partners, Offertes, Meldkameraansluitingen	Koppelen in geheugen i.p.v. gefilterd ophalen	Laadtijd groeit lineair met de data	P2	Filteren op de server, alleen nodige velden, paginering	M
13	Geen transacties bij meerstapsschrijven	Aanmeldingen + regels, adressen; factuurruns	Zite-SDK heeft geen transacties	Halve dossiers of runs na een storing	P2	Idempotentiesleutels (al bij indienen) uitbreiden + herstelcontrole	M
14	Gelijktijdig bewerken van JSON-velden	Aanmeldingen, Partners	Lezen-wijzigen-schrijven zonder versiecontrole	Laatste opslag wint; wijziging van een collega verdwijnt stil	P2	Versiecontrole op `gewijzigdOp` bij opslaan	M
15	Scheiding tussen partners alleen in code	Alle partnertabellen	Zite heeft geen rijbeveiliging	Een nieuw endpoint zonder controle lekt data	P2	Centrale hulpfunctie + test die alle portaal-endpoints nagaat	M
16	JSON-lijsten van id's zonder integriteit	Documenten, Documentpakketten	Gemak bij bouwen	Verwijzing naar verwijderde partner of document blijft hangen	P3	Koppelvelden	S
17	Partner van een concept als tekst	Concepten	Gemak bij bouwen	Concept kan verweesd raken	P3	Koppelveld naar Partners	S

Rapport 3 — Before vs after

De kern blijft staan; drie zware structuren worden opgeknipt en elke verwijzing naar een persoon of record krijgt een echte koppeling. Bij een volledig nieuw ontwerp zou ik vooral het dossier opdelen in fasen en klant en adres op één plek houden; de rest van het model is verdedigbaar.

Ontwerpkeuze	Wat	Waarom
A. Behouden	Partners, Aanmelders, Vestigingen, Diensten, Partnertarieven, Offertes, Meldkameraansluitingen, Aansluitdiensten, Factuurregels, Wijzigingen, Producttaken, Onboarding, Fasewissels, Notities	Heldere verantwoordelijkheid per tabel en schone data
A. Behouden als snapshot	JSON in Offertes.regels, Factuurruns.regels, Indexaties.oude prijzen	Een vastgelegde momentopname hoort niet mee te veranderen

Ontwerpkeuze	Wat	Waarom
B. Optimaliseren	Cardinaliteit van 3 koppelingen; opruimen van Beheersessies; veldselectie in lijsten	Kleine wijziging, direct minder risico
C. Herstructureren	Klantgegevens: Klanten en Locaties de enige bron, het dossier verwijst	Eén plek om te corrigeren
D. Samenvoegen	Locaties in Klanten (adres per klant) als blijkt dat een klant nooit meerdere objecten heeft	Locaties wordt nu door 1 module gebruikt; eerst gebruik meten
E. Splitsen	Aanmeldingen → dossier (kern, ~35 velden) + Installatie (technische gegevens, WePrevent) + Controles (eerste, finale, klantgegevensstatus) + Commerciele afspraak; Logboek → Logboek (audit) + Verzendlog	Eén verantwoordelijkheid per tabel; lijsten laden alleen de kern
F. Uitfaseren	Aanmeldingen.aanmelder (tekst) en aanmelderEmail naast de koppelingen sales en monteur; Aansluitdiensten.aanvraag (af te leiden via de aansluiting)	Dubbele bron
G. Toevoegen	Koppelingen naar Beheergebruikers (proceseigenaar, eigenaar, vervanger); koppelingen in Documenten en Concepten; hashkolommen voor sleutels; versieveld voor gelijktijdig bewerken; auditvelden (entiteit, veld, oud, nieuw, bron)	Integriteit en herleidbaarheid

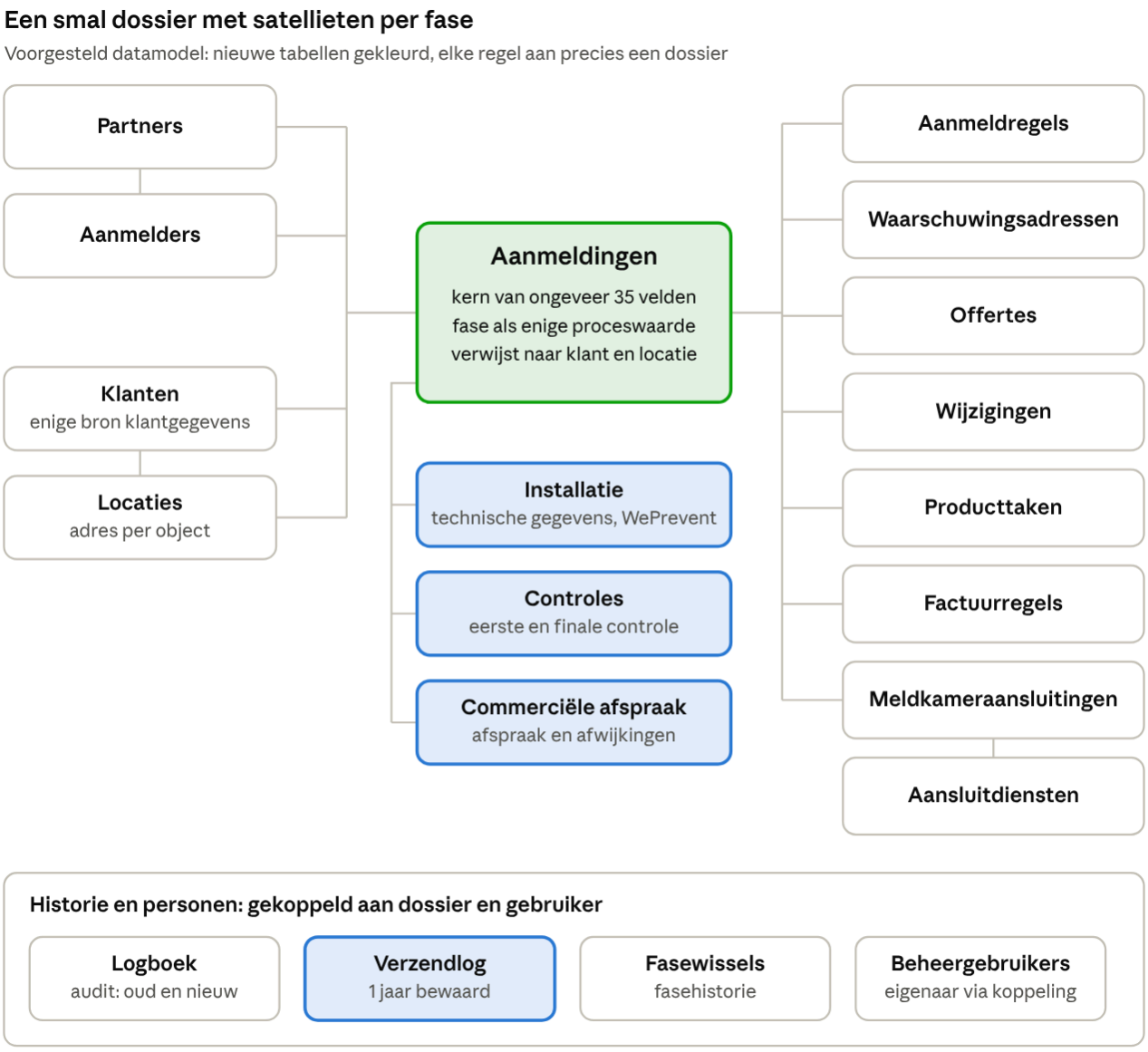
Wat verandert er voor bestaande functies. Elke wijziging in deze tabel raakt endpoints die nu werken. Daarom gaat elke stap via dezelfde methode als vandaag: uitvoer van de betrokken endpoints vastleggen, wijzigen, uitvoer moet gelijk blijven.

- Splitsen van Aanmeldingen raakt 93 endpoints en modules (23 portaal, 44 beheer, 26 servermodules). Dat is de grootste klus en gebeurt per satelliet, met een overgangsperiode waarin oud en nieuw allebei gevuld worden.
- Klant als enige bron raakt de aanvraagwizard, offertes, facturatie en de klantlink.

- Hashen van sleutels raakt alleen de vijf opzoekfuncties; bestaande persoonlijke links blijven werken.

Verwachte performance. Gemeten vandaag: lichte veldselectie maakt de dossierlijst 3x kleiner. Onderbouwde verwachting: na het splitsen draagt een lijstrij ongeveer 35 in plaats van 101 velden, en blijven lijsten bij 10x zoveel dossiers onder 1 s mits filteren en paginering op de server gebeuren. Niet bewezen: het effect van indexen, omdat die niet zichtbaar zijn.

Voorgesteld datamodel



voorgesteld datamodel · vier nieuwe tabellen

Het dossier houdt alleen de kern; installatie, controles en de commerciële afspraak krijgen een eigen tabel, de verzendlog gaat uit het logboek, en personen worden gekoppeld in plaats van als tekst opgeslagen.

Rapport 4 — Optimization backlog

Zeventien acties, in volgorde van uitvoering; nummers verwijzen naar Rapport 2. Inspanning S = uren, M = dagen, L = weken.

#	Prioriteit	Actie	Verwachte impact	Inspanning	Risico	Afhankelijk van	Test
1	P0 kritiek	Codewoordsleutel instellen (jij), daarna codewoorden versleutelen (script)	Codewoorden onleesbaar bij datalek	S	Sleutel kwijt = codewoorden kwijt: sleutel apart bewaren	Sleutel door jou ingesteld	Aantal versleuteld = aantal gevuld; meldkamer ziet codewoord nog correct
2	P0 kritiek	KVK-sleutel roteren (jij)	Oude sleutel onbruikbaar	S	Geen	—	KVK-zoeken werkt na rotatie
3	P1 hoog	Sleutels hashen: hashveld vullen, opzoeken via hash, platte waarde wissen na 2 weken	Gestolen database geeft geen toegang	M	Een link die alleen op de oude waarde zoekt, werkt niet meer	—	Inloggen met elke bestaande link voor en na; vergelijking van portaaluitvoer
4	P1 hoog	Verlopen beheersessies nachtelijk opruimen	Geen oude tokens, minder groei	S	Laag: alleen verlopen sessies	—	Proefrun telt; geldige sessie blijft
5	P1 hoog	Cardinaliteit 3 koppelingen naar “één”	Fout wordt onmogelijk in plaats van stil	S	Zite-veldwijziging; nu 0 overtredingen	Controle direct vooraf	Auditscript opnieuw: 0 afwijkingen
6	P1 hoog	Factuurregels completeren + factuurrun weigeren bij ontbrekende velden	Geen facturen van €0	S	Laag	Jouw btw-codes en grootboek	Run-voorbeeld toont bedragen
7	P2 middel	Centrale uniciteitscontrole bij schrijven + dagelijkse integriteitscontrole	Dubbelen worden voorkomen of de volgende ochtend gemeld	M	Laag	—	Dubbele waarde proberen: geweigerd
8	P2 middel	Verzendlog naar eigen tabel	Logboek groeit trager; mails apart te bewaren en op te schonen	M	Middel: 4 schermen lezen de verzendlog	—	Uitvoer Verzonden mails gelijk
9	P2 middel	Auditvelden in Logboek (entiteit, veld, oud, nieuw, bron) voor kerngegevens	Wie wijzigde wat, van welke waarde, herleidbaar	M	Laag: alleen toevoegen	8	Wijziging dossier toont oud en nieuw
10	P2 middel	Personen koppelen aan Beheergebruikers	E-mailwijziging breekt niets meer	M	Middel: migratie van tekst naar koppeling	—	Mijn processen en Mijn taken gelijk
11	P2 middel	Versiecontrole bij opslaan van dossier- en partner-JSON	Geen stil overschrijven door een collega	M	Laag: melding bij conflict	—	Twee gelijktijdige opslagen: tweede krijgt melding
12	P2 middel	Paginering en filteren op de server in de grote lijsten	Lijsten blijven snel bij 10x data	M	Middel: zoeken en sorteren verhuizen naar de server	—	Uitvoer gelijk bij volledige pagina; tijd per pagina
13	P2 middel	Idempotentie en herstelcontrole voor factuurrun en fasewissel	Geen halve runs of dubbele taken na een storing	M	Laag	7	Storing nabootsen in test: geen dubbelen
14	P2 middel	Centrale partnercontrole + test over alle portaal-endpoints	Nieuw endpoint kan geen data van een andere partner lekken	M	Laag	—	Test met sleutel van partner A op dossier van B: overal geweigerd

#	Prioriteit	Actie	Verwachte impact	Inspanning	Risico	Afhankelijk van	Test
15	P2 middel	Aanmeldingen splitsen in satellieten, per satelliet	Lijsten 3x lichter, schema overzichtelijk	L	Hoog: raakt 93 endpoints	10, 11	Volledige vergelijking per satelliet
16	P3 laag	Klant en adres op één plek	Eén correctie overal zichtbaar	L	Hoog: wizard, offertes, facturatie	15	Offerte- en factuuruitvoer gelijk
17	P3 laag	Koppelvelden in Documenten, Documentpakketten en Concepten	Geen verweesde verwijzingen	S	Laag	—	Documenten per partner gelijk

Rapport 5 — Implementatieplan

Zes fasen; A en B kunnen direct en los van elkaar, C pas als B staat. Elke fase gaat pas live na jouw akkoord en na een gelijke uitvoer in de vergelijkingstest.

Fase	Acties (backlog #)	Zelfstandig of afhankelijk	Klaar wanneer
A. Veilige quick wins	1, 2, 4, 5, 6	Zelfstandig; 1, 2 en 6 vragen eerst iets van jou	Auditscript: 0 onversleutelde codewoorden, 0 verlopen sessies, 0 koppelingen met meer dan één
B. Datakwaliteit en integriteit	3, 7, 13, 14	Zelfstandig van A; 13 na 7	Elke bestaande link werkt via de hash; integriteitscontrole draait dagelijks zonder meldingen
C. Structurele verbeteringen	8, 9, 10, 17	9 na 8	Verzendlog en audit apart; alle personen gekoppeld
D. Backend- en applicatieaanpassingen	11, 12	Na C voor de dossierschermen	Conflictmelding bij gelijktijdig opslaan; lijsten met paginering
E. Performance en schaalbaarheid	15, 16	Na D; per satelliet in kleine stappen	Lijsten laden alleen de kern; klant op één plek

Fase	Acties (backlog #)	Zelfstandig of afhankelijk	Klaar wanneer
F. Verificatie en monitoring	Doorlopend	Na elke fase	Vergelijkingstest gelijk, performancemeting stabiel, integriteitscontrole schoon

Fase E is alleen nodig als de dagelijkse performancemeting groei laat zien; bij het huidige volume is A t/m D de verstandige grens.

Rapport 6 — Business impact

De grootste winst is minder risico, niet meer snelheid: na fase A en B is een gelekte database niet meer genoeg om in te loggen of een alarm af te melden.

Vraag	Antwoord	Zekerheid
Wat wordt sneller?	Dossierlijsten en zoeken nu al 3x minder data per dossier; na paginering blijven lijsten snel bij groei	Gemeten (veldselectie); verwacht (paginering)
Wat wordt betrouwbaarder?	Geen facturen van €0, geen stil overschreven dossiers, geen dubbele codes, geen halve runs	Verwacht, per actie te testen
Wat wordt veiliger?	Codewoorden versleuteld, sleutels alleen als hash, geen oude tokens	Verwacht; codewoordversleuteling zelf is al getest
Wat wordt eenvoudiger?	Klant op één plek corrigeren; schema per fase leesbaar	Verwacht (fase E)
Welke fouten verdwijnen?	Proceseigenaar kwijt na e-mailwijziging; regel aan twee dossiers; mail naar verdwenen record	Onderbouwd uit de code
Onderhoud bespaard	Minder handmatige veldlijsten en minder plekken met eigen controles	Niet gekwantificeerd

Vraag	Antwoord	Zekerheid
Groeiruimte	Huidige opzet loopt bij 10x dossiers op tot seconden per lijst; na A t/m D blijft dat onder 1 s	Afgeleid uit lineaire laadtijd; niet met echte belasting getest
Merkt een gebruiker	Snellere lijsten, een melding bij gelijktijdig bewerken, correcte facturen	Verwacht
Merkt een ontwikkelaar	Minder brede tabellen, centrale controles, een test die partnerscheiding bewaakt	Verwacht

Migratie, tests en voorbereide scripts

Elke wijziging volgt dezelfde tien stappen, met als harde regel: geen productiewijziging zonder jouw akkoord op die specifieke fase.

1. Afhankelijkheden in kaart: welke endpoints en schermen lezen of schrijven de tabel (zie Database inventory).
2. Wijziging ontwerpen, met proefmodus die alleen telt.
3. Uitvoer van alle betrokken endpoints vastleggen (vingerafdruk per endpoint, al gebouwd voor 20 beheer- en 6 logboekschermen en de portaalfacturen).
4. Impact op workflows en automatiseringen nagaan (geplande taken, mails).
5. Herstelplan: Zite-veldwijzigingen zijn omkeerbaar; bij datamigraties eerst een export van de betrokken records.
6. Migratie in kleine stappen, oud en nieuw tijdelijk naast elkaar.
7. Testen met ZZTEST-records, daarna opruimen op exacte id’s.
8. Bestaande data valideren met het auditscript (aantallen voor en na gelijk, 0 verweesde koppelingen).
9. Regressie: vingerafdrukken voor en na exact gelijk.
10. Gecontroleerde release: commit, build, publiceren, performancemeting de dag erna.

Testdekking per release. Statusovergangen (fasewissel per partnerrol), rechten (sleutel van partner A op dossier van B), zoeken en filters, dashboards en inzichten, facturatie en factuurrun, automatiseringen in proefmodus, gelijktijdig opslaan, en recordaantallen plus checksums voor en na.

Voorbereid, niet uitgevoerd (in de sandbox, `tests/migratiesFaseA.ts`, standaard proef):

- `versleutelCodewoorden` — weigert zonder sleutel; versleutelt daarna alleen nog onversleutelde codewoorden en telt na;
- `ruimBeheersessiesOp` — verwijdert uitsluitend sessies waarvan de vervaldatum voorbij is;
- `controleerCardinaliteit` — de controle vóór het omzetten van de drie koppelingen naar “één” (nu 0 overtredingen).

Het auditscript zelf (`tests/audit.ts`) is herhaalbaar en geeft alleen aantallen terug.

Vijf belangrijkste aanbevelingen

1. Stel vandaag de codewoordsleutel in en roteer de KVK-sleutel; daarna versleutel ik de codewoorden.
2. Sla toegangssleutels en tokens alleen nog als hash op, en ruim verlopen sessies op.
3. Zet de drie koppelingen op “één” en laat de factuurrun weigeren bij ontbrekende factuurgegevens.
4. Koppel personen aan Beheergebruikers en scheid de verzendlog van het logboek.
5. Begin pas aan het splitsen van Aanmeldingen als de dagelijkse meting groei laat zien.

Toestemming nodig. Wil je dat ik fase A uitvoer zodra jij de codewoordsleutel en de nieuwe KVK-sleutel hebt ingesteld, en geef je de btw-codes en grootboekrekeningen voor de drie factuurregels?